

SECURITY INCIDENT REPORT

Brute-Force Authentication Attempt — Wazuh SIEM Detection Lab

SEVERITY: MEDIUM

Incident ID	INC-2026-001
Report Date	July 30, 2026
Analyst	Oluwadare Dotun
Status	Closed — Confirmed Simulation
Detection Source	Wazuh SIEM (Rule ID 60204)
MITRE ATT&CK Technique	T1110 — Brute Force (Credential Access)

1. Executive Summary

On July 30, 2026, the Wazuh SIEM deployed in a home lab environment detected a brute-force authentication attempt against a local Windows endpoint (DESKTOP-62DSVDO). Between 15:45:25 and 15:45:58 UTC, eight consecutive failed logon attempts (Event ID 4625) were recorded against the local account “testuser,” using Logon Type 3 (network) with NTLM authentication. Wazuh's correlation engine (Rule ID 60204) escalated the activity to a level 10 alert, mapped to MITRE ATT&CK technique T1110 (Brute Force). The evenly-spaced timing of the attempts and a preceding PowerShell execution event indicate the activity was scripted rather than manually typed. No successful authentication occurred; the target account was not compromised at any point. The incident was investigated and confirmed as a controlled brute-force simulation conducted for detection-engineering purposes.

2. Incident Overview

Date/Time Detected	2026-07-30 15:47:17 UTC (Wazuh alert generation)
Date/Time Occurred	2026-07-30 15:45:25 – 15:45:58 UTC
Detected By	Wazuh SIEM — Rule ID 60204
Incident Category	Brute Force / Credential Access
Affected Environment	Home lab — isolated Windows 10 VM with Wazuh agent

3. What Happened

3.1 Summary of Events

At approximately 15:45:21 UTC, a PowerShell script began executing on DESKTOP-62DSVDO, querying system environment variables (Wazuh Rule 91816) — this preceded the first failed logon by roughly four seconds and establishes that a script, not a human, drove the subsequent activity. Between 15:45:25 and 15:45:58 UTC, eight sequential authentication attempts were made against the local account “testuser” over the network authentication path (Logon Type 3, NTLM). Each attempt failed with “Unknown user name or bad password” (Status 0xC000006D). The attempts originated from the host's own network stack (IPv6 link-local source, workstationName: DESKTOP-62DSVDO), consistent with a locally-run script authenticating outward through SMB/NTLM rather than a truly external attacker. Once the eighth failure was logged, Wazuh's correlation rule crossed its configured threshold (frequency: 8) and generated a level 10 alert.

3.2 Timeline of Events

Timestamp	Event Source	Description
15:45:21 (approx.)	Wazuh (Rule 91816)	PowerShell script execution detected, querying system environment variables
15:45:25.758	Wazuh (Rule 60122)	Failed logon attempt #1 against testuser

Timestamp	Event Source	Description
15:45:40.941	Wazuh (Rule 60122)	Failed logon attempt #2
15:45:43.950	Wazuh (Rule 60122)	Failed logon attempt #3
15:45:46.901	Wazuh (Rule 60122)	Failed logon attempt #4
15:45:49.800	Wazuh (Rule 60122)	Failed logon attempt #5
15:45:52.689	Wazuh (Rule 60122)	Failed logon attempt #6
15:45:55.608	Wazuh (Rule 60122)	Failed logon attempt #7
15:45:58.485	Wazuh (Rule 60122)	Failed logon attempt #8
15:47:17.915	Wazuh (Rule 60204)	Correlation threshold met — “Multiple Windows Logon Failures” alert generated, level 10

4. User(s) Involved

Target Username	testuser (local account)
Account Type	Local
Privilege Level	Standard user (test account, non-administrative)
Logon Type	3 (Network)
Authentication Package	NTLM
Source Address	fe80::db20:45ed:7c76:d1a5 (IPv6 link-local — same host)
Account Status Post-Incident	No lockout policy triggered; recommend reviewing account lockout threshold (see Section 9)

5. Affected Machine(s)

Hostname	IP Address	OS / Version	Role / Criticality
DESKTOP-62DSVDO (agent: dotsec)	192.168.1.54	Windows 10	Lab test endpoint / Low

6. Why This Is Suspicious

- Volume and pattern: Eight failed authentication attempts against the same account within a 33-second window is well outside normal user behavior — a person mistyping a password rarely exceeds 2–3 attempts before pausing or requesting a reset.

- Timing regularity: Attempts 2 through 8 landed at near-identical ~3-second intervals. Human typing produces irregular gaps; this consistency is a strong indicator of scripted, automated execution.
- Preceding process activity: A PowerShell script executed seconds before the first failure, correlating tool execution directly with the onset of the authentication attempts — this ties the failures to an identifiable process rather than an isolated fluke.
- Authentication vector: Logon Type 3 (network/NTLM) rather than Type 2 (interactive) indicates the attempts were made programmatically over the network stack rather than typed at the console — consistent with credential-stuffing or brute-force tooling behavior.
- MITRE ATT&CK alignment: The behavior maps cleanly to T1110 (Brute Force) under the Credential Access tactic — repeated, automated authentication attempts against a single account are a textbook precursor to credential compromise.
- Benign explanation considered and weighed against: A legitimate user repeatedly mistyping a password was considered, but the interval regularity and correlated script execution make automated/malicious tooling substantially more likely than user error.

7. Detection Details (Wazuh)

Wazuh Rule ID	60204 (correlation) / 60122 (individual failures)
Rule Description	“Multiple Windows Logon Failures”
Rule Level (Severity)	10
Correlation Threshold	8 matching events
Log Source	Windows Security Event Log (Event ID 4625) via Wazuh eventchannel
MITRE Technique	T1110 — Brute Force (Credential Access)

7.1 Raw Log Excerpt (Correlation Alert, Rule 60204)

```
eventID: 4625
logonType: 3
authenticationPackageName: NTLM
targetUserName: testuser
targetDomainName: DESKTOP-62DSVDO
ipAddress: fe80::db20:45ed:7c76:d1a5
failureReason: Unknown user name or bad password
status: 0xc000006d / subStatus: 0xc0000064
rule.id: 60204 | level: 10 | frequency: 8
rule.mitre.id: T1110 | tactic: Credential Access
```

7.2 Supporting Evidence

[Insert screenshots: Wazuh Discover table showing escalation from Rule 60122 (level 5) to Rule 60204 (level 10); raw JSON of the correlation alert; PowerShell execution transcript.]

8. Impact Assessment

Confidentiality Impact	None — no successful authentication occurred; no credentials or data exposed
Integrity Impact	None — no system or account modifications occurred
Availability Impact	None — target account was not locked out (see Section 9 recommendation)
Scope	Single endpoint, self-originated traffic; no lateral movement observed

In a real-world unmitigated scenario, sustained brute-force activity of this nature — if directed at a privileged or externally-reachable account — could lead to credential compromise, unauthorized access, and a foothold for lateral movement or further privilege escalation. The absence of an account lockout policy in this environment means an attacker with a larger password list and more time would not be automatically throttled or blocked, which materially increases real-world risk.

9. Recommendations & Remediation

9.1 Immediate Actions

- Confirm the testuser account password was not compromised; reset as a precaution
- Review the source process (PowerShell) for legitimacy — confirmed as authorized test activity in this case

9.2 Short-Term Actions

- Implement an account lockout policy (e.g. lock after 5 failed attempts within 5 minutes) to throttle brute-force attempts at the OS level
- Lower the Wazuh correlation frequency threshold for this rule group to reduce detection latency (current correlation took ~79 seconds after the final failed attempt to fire)
- Enable PowerShell Script Block Logging to capture full command content for any script-driven authentication activity

9.3 Long-Term Recommendations

- Deploy Sysmon for enhanced process-to-network correlation (tying PowerShell execution directly to subsequent network connections)
- Add this detection pattern (T1110 / Rule 60204) to the SOC playbook with documented triage and response steps
- Consider integrating threat intelligence feeds to auto-enrich source IPs on future external-facing brute-force alerts

10. Lessons Learned

- Wazuh's out-of-the-box correlation rule (60204) correctly escalated a burst of low-severity events (level 5) into a high-confidence, high-severity alert (level 10) without custom rule authoring — validating the default ruleset for this technique.

- Detection latency (~79 seconds between the final failed logon and alert generation) is a gap worth investigating further — in a live SOC this affects mean-time-to-detect (MTTD) and should be tuned.
- Correlating the preceding PowerShell execution event with the authentication failures was key to confidently ruling out user error — reinforces the value of cross-referencing multiple log sources rather than triaging alerts in isolation.
- Next iteration: source the brute-force attempt from a second VM with a distinct IP to simulate a genuinely external attacker and produce a network-perimeter-facing version of this scenario.

Appendix A: Environment Details

- SIEM: Wazuh (manager: wazuh-server)
- Agent: dotsec (agent ID 001), IP 192.168.1.54
- Endpoint OS: Windows 10, hostname DESKTOP-62DSVDO
- Simulation Method: PowerShell script iterating incorrect credentials against a local test account over SMB/NTLM
- Network: Isolated home lab (no production systems involved)

— End of Report —